

Databehandleravtale (DBA) — Boly

i henhold til GDPR artikkel 28 nr. 3

Mellom:

[FYLL INN KOMMUNENS NAVN] Org.nr. [FYLL INN kommunens org.nr.] [FYLL INN kommunens besøksadresse] («Behandlingsansvarlig»)

og

GAMECHANGING AS Org.nr. 932 496 321 Lavangnesveien 2039, 9350 Sjøvegan («Databehandler»)

Tjeneste: Boly — digital formidlingsplattform for kommunal boligbistand (bolynorge.no).

Dato: [FYLL INN signeringsdato]

Konfidensielt — kun til partenes bruk.

Felt markert med **[FYLL INN ...]** skal utfylles av partene ved signering.

Parter

Denne avtalen regulerer forholdet mellom Behandlingsansvarlig og Databehandler når Databehandler behandler personopplysninger på vegne av Behandlingsansvarlig, jf. **GDPR art. 28** og personopplysningsloven § 17.

	Behandlingsansvarlig	Databehandler
Navn	[FYLL INN KOMMUNENS NAVN]	Gamechanging AS
Org.nr.	[FYLL INN kommunens org.nr.]	932 496 321
Adresse	[FYLL INN kommunens besøksadresse]	Lavangnesveien 2039, 9350 Sjøvegan
Kontaktperson	[FYLL INN navn + e-post + tlf]	Lars Utstøl, lars@gamechanging.no , +47 416 13 301
Personvernombud (DPO)	[FYLL INN navn + e-post + tlf]	Ikke pliktig etter GDPR art. 37, men personvernkontakt: security@bolynorge.no
Sikkerhetskontakt	[FYLL INN dedikert sikkerhetsadresse, 24/7]	security@bolynorge.no (24/7 monitort)

§1. Formål og virkeområde

- 1.1. Avtalen regulerer Databehandlers behandling av personopplysninger på vegne av Behandlingsansvarlig i forbindelse med tjenesten Boly.
- 1.2. Behandlingens formål, art, varighet, typer personopplysninger og kategorier av registrerte fremgår av **Vedlegg A**.
- 1.3. Ved motstrid mellom Hovedavtalen (SaaS-avtalen) og denne DBA, går DBA foran for personvernspørsmål.
- 1.4. DBA omfatter all behandling av personopplysninger som Databehandler utfører på vegne av Behandlingsansvarlig, uavhengig av om behandlingen skjer i produksjon, test, demo, eller midlertidige miljøer som drift krever.

§2. Definisjoner

Begrepene i denne avtalen tolkes i samsvar med GDPR art. 4 og personopplysningsloven. Sentrale definisjoner:

- **Personopplysninger:** enhver opplysning om en identifisert eller identifiserbar fysisk person, jf. GDPR art. 4 nr. 1.
 - **Behandling:** enhver operasjon som utføres med personopplysninger, jf. GDPR art. 4 nr. 2.
 - **Registrert:** fysisk person som personopplysningene gjelder.
 - **Underdatabehandler:** annen databehandler som Databehandler engasjerer, jf. GDPR art. 28 nr. 2 og nr. 4.
 - **SCC:** Standard Contractual Clauses — Kommisjonens gjennomføringsavgjørelse (EU) 2021/914.
 - **TIA:** Transfer Impact Assessment, jf. EDPB Rec. 01/2020 v2.0.
 - **Sikkerhetsbrudd / brudd på personopplysningsikkerheten:** hendelse som fører til utilsiktet eller ulovlig tilintetgjørelse, tap, endring, ulovlig spredning av eller tilgang til personopplysninger, jf. GDPR art. 4 nr. 12.
-

§3. Databehandlers plikter

3.1. **Instruksbinding.** Databehandler behandler kun personopplysninger etter dokumenterte instruks fra Behandlingsansvarlig, herunder om overføring til tredjeland, med mindre EU/EØS-rett pålegger noe annet, jf. GDPR art. 28 nr. 3 bokstav a. Denne DBA og Hovedavtalen utgjør slik dokumentert instruks.

3.2. **Konfidensialitet.** Databehandler sørger for at enhver som er autorisert til å behandle personopplysningene har forpliktet seg til konfidensialitet eller er underlagt lovfestet taushetsplikt. Konfidensialitetsforpliktelsen gjelder **også etter avtaleoppør** og uten tidsbegrensning for taushetsbelagte opplysninger.

3.3. **Sikkerhet.** Databehandler iverksetter egnede tekniske og organisatoriske tiltak som beskrevet i **Vedlegg C**, jf. GDPR art. 32.

3.4. **Assistanse med registrertes rettigheter.** Databehandler bistår Behandlingsansvarlig med å ivareta registrertes rettigheter (GDPR kap. III), herunder innsyn, retting, sletting, begrensning, dataportabilitet og protest. Bistand gis uten ytterligere vederlag så fremt forespørselen er av ordinært omfang. For ekstraordinære, gjentakende eller åpenbart grunnløse forespørsler kan Databehandler fakturere etter medgått tid til ordinær timesats.

3.5. **Assistanse med art. 32–36.** Databehandler bistår med sikkerhetsbruddvarsling, DPIA og forhåndskonsultasjon i rimelig utstrekning, jf. §3.4 siste punktum om vederlag.

3.6. **Varsling om instruks i strid med lov.** Databehandler skal umiddelbart varsle Behandlingsansvarlig dersom en instruks anses å stride mot GDPR eller annen personvernlovgivning.

3.7. **Taushetspliktserklæring.** Alle ansatte og innleide som har tilgang til Boly-data er underlagt skriftlig taushetspliktserklæring.

3.8. **Egen protokoll (GDPR art. 30 nr. 2).** Databehandler fører egen fortegnelse over kategorier av behandlingsaktiviteter utført på vegne av Behandlingsansvarlig, og gjør denne tilgjengelig for Behandlingsansvarlig og tilsynsmyndighet på forespørsel.

§4. Behandlingsansvarliges plikter

4.1. Behandlingsansvarlig er ansvarlig for at det foreligger behandlingsgrunnlag for behandlingen, jf. GDPR art. 6 (og art. 9 der aktuelt).

4.2. Behandlingsansvarlig skal ikke overføre personopplysninger til Databehandler som ikke er nødvendige for formålet beskrevet i Vedlegg A, jf. prinsippet om dataminimering (GDPR art. 5 nr. 1 bokstav c).

4.3. Behandlingsansvarlig skal gjennomføre DPIA når det er påkrevd (GDPR art. 35), og eventuelt forhåndskonsultasjon (art. 36). Databehandler bistår med teknisk grunnlag, herunder Boly-DPIA-en som følger denne

DBA-en som separat vedlegg.

4.4. Behandlingsansvarlig plikter å informere egne registrerte etter GDPR art. 13/14 (personvernerklæringen som følger denne DBA-en som separat vedlegg kan brukes som utgangspunkt) og å føre egen protokoll over behandlingsaktiviteter etter art. 30 nr. 1, der denne behandlingen skal inngå.

4.5. Behandlingsansvarlig skal registrere en aktiv DPO-kontakt (navn + e-post) for egen kommune i Boly-plattformens register over kommunale personvernombud, slik at registrertes GDPR-forespørsler kan rutes korrekt fra selvbetjeningsflyten.

§5. Underdatabehandlere

5.1. Databehandler har Behandlingsansvarligs generelle forhånds godkjenning til å benytte underdatabehandlere som angitt i **Vedlegg B**.

5.2. Ved endringer av underdatabehandlere skal Behandlingsansvarlig varsles skriftlig minst **30 dager** før endringen trer i kraft. Behandlingsansvarlig kan innen denne fristen gjøre begrunnede innsigelser. Dersom enighet ikke oppnås, kan Behandlingsansvarlig si opp avtalen med 30 dagers varsel uten vederlagsplikt for gjenstående bindingstid.

5.3. Databehandler pålegger underdatabehandlerne de samme forpliktelser som følger av denne avtalen, og forblir fullt ansvarlig overfor Behandlingsansvarlig for underdatabehandlernes oppfyllelse.

5.4. **Leverandørenes egne varslingsfrister.** Enkelte underdata behandlere opererer med kortere varslingsfrister for egne under leverandør-endringer (f.eks. Vercel DPA §7.c: 5 kalenderdager). Databehandler håndterer dette ved å:

- videresende varsel til Behandlingsansvarlig **uten ugrunnet opphold** og senest innen 48 timer etter mottak;
- opprettholde egen 30-dagers vurderingsperiode overfor Behandlings ansvarlig i henhold til §5.2, selv om leverandørens formelle objektfrist er kortere;
- bære risikoen for differansen mellom leverandørens frist og den avtalte fristen overfor Behandlingsansvarlig.

§6. Overføring til tredjeland

6.1. **Hovedregel: EU/EØS-innenlands behandling.** Alle persondatalagre ligger innenfor EU/EØS:

- Supabase: AWS `eu-central-1` (Frankfurt, Tyskland) — Postgres, Auth, Storage.
- Vercel: `arn1` (Stockholm, Sverige) — serverside-funksjoner, pinnet via `vercel.json`.
- Vercel Edge Middleware kjører på Vercels globalt distribuerte edge-CDN; **persisterer ingen personopplysninger**, men JWT-cookies fra brukeren passerer gjennom og videresendes til Supabase for verifisering.

6.2. **Tredjelandsoverføringer:** Supabase Inc. og Vercel Inc. har begge morselskap i USA og kan i begrensede tilfeller (support, drift) få tilgang til data. Overføringene er dekket av:

- **SCC** (Kommisjonens gjennomføringsavgjørelse (EU) 2021/914).
- **TIA** — se Vedlegg B.2.
- Der det er aktuelt: **Data Privacy Framework** (DPF).

6.3. Ingen annen overføring av personopplysninger til tredjeland er godkjent uten ny skriftlig instruks fra Behandlingsansvarlig.

§7. Sikkerhet

7.1. Databehandler iverksetter tekniske og organisatoriske tiltak som sikrer et sikkerhetsnivå som er egnet i forhold til risikoen, jf. GDPR art. 32. Tiltakene er spesifisert i **Vedlegg C**.

7.2. Databehandler gjennomfører jevnlige risikovurderinger og oppdaterer tiltakene når risikobildet endres vesentlig, og minst årlig.

§8. Avvik, sikkerhetsbrudd og varsling

8.1. **Varslingsfrist.** Databehandler skal varsle Behandlingsansvarlig om brudd på personopplysningsikkerheten **uten ugrunnet opphold** og senest innen 24 timer etter at Databehandler fikk kjennskap til det.

8.2. **Varslingsadresser:**

Type	Adresse
Primær, 24/7-monitort	<code>security@bolynorge.no</code>
Sekundær / personvernaglig	<code>security@bolynorge.no</code>
Behandlingsansvarliges mottaker	[FYLL INN kommunens dedikerte sikkerhetsadresse]

Se **Vedlegg C.9** for detaljert eskaleringsstige.

8.3. **Varselets innhold** (i tråd med GDPR art. 33 nr. 3):

- Arten av bruddet.
- Hvilke kategorier og omtrentlig antall registrerte berørt.
- Hvilke kategorier og omtrentlig antall personopplysninger.
- Sannsynlige konsekvenser.
- Iverksatte eller foreslåtte tiltak, inklusive oppdatert rotårsaksanalyse når denne foreligger.

8.4. Behandlingsansvarlig har 72-timers frist til Datatilsynet, jf. GDPR art. 33 nr. 1.

8.5. Varsling til registrerte (GDPR art. 34) er Behandlingsansvarliges ansvar; Databehandler bistår teknisk (varslingskanaler i Boly, brukerliste) på forespørsel.

§9. Sletting og retur ved avtaleopphør

9.1. Ved opphør av avtalen skal Databehandler, etter Behandlingsansvarliges valg:

- (a) Slette alle personopplysninger og bekrefte slettingen skriftlig, eller
- (b) Returnere opplysningene i strukturert, alminnelig anvendt og maskinlesbart format.

9.2. Sletting skal skje innen **60 dager** etter avtaleopphør, med mindre lov eller rettslig plikt krever lengre oppbevaring. For poster underlagt lovpålagt oppbevaring (f.eks. bokføringsloven § 13 for signerte avtaler) opprettholdes kun de felter som er nødvendige for lovoppfyllelsen; øvrige felter slettes eller pseudonymiseres.

9.3. **Pseudonymisering som alternativ til sletting (legal hold).** For rader som må beholdes for å dokumentere signert samtykke eller kontraktsforhold (BankID-signeringsspor, versjonerte vilkårs akseptanser, sikkerhetsrelevante audit-logger) nulles bruker referansen (`user_id`) og erstattes av et deterministisk pseudonym (uuid-v5 med server-side pepper) i en dedikert kolonne (`user_id_pseudonym`). Pseudonymet gjør det mulig å korrelere rader tilhørende samme slettede bruker for revisjon uten å kunne mappe tilbake til identiteten **via pseudonym-feltet selv**.

Pseudonymiseringsarbeidet er faset:

- **Fase 1 (levert):** FK-policy for `user_agreements`, `user_terms_acceptances` og `audit_logs` endret fra `ON DELETE CASCADE` til `ON DELETE SET NULL`. Kolonnen `user_id_pseudonym` opprettet. Tombstone-rader overlever auth-sletting; selvbetjent sletteknapp er ikke eksponert for sluttbruker i denne fasen.
- **Fase 2 (planlagt, Vedlegg F.1):** Erasure-RPC som (a) fyller ut `user_id_pseudonym`, (b) masker indirekte PII i `audit_logs` (boligadresse → kommune+postnummer, fjerner BankID-sesjons-ID `signingSessionId` fra `details` -JSON), og (c) fjerner BankID- bundne felter fra `user_agreements` som ikke er strengt nødvendige for bokføringsloven § 13 (3).
- **Fase 3 (planlagt, Vedlegg F.1):** Utvidelse av nattlig retensjonsjobb for å slette tombstone-rader som har vært pseudonymiserte i mer enn 5 år.

Inntil fase 2 er på plass vil tombstone-rader fortsatt kunne inne holde INDIREKTE personopplysninger (f.eks. boligadresse eller Signicat-sesjons-ID) som teoretisk kan spores tilbake til person via eksterne systemer. Dette er tillatt legal hold etter GDPR art. 17 nr. 3 bokstav b (rettskrav) og bokstav e (allmennhetens interesse av dokumentasjon i bokføringslovens forstand), og skal ikke behandles aktivt for andre formål enn revisjon eller rettslige krav.

9.4. Se **Vedlegg C.4** for løpende retensjon under avtalens løpetid.

§10. Revisjon

10.1. Behandlingsansvarlig har rett til å gjennomføre revisjon av Databehandlers etterlevelse av denne avtalen, inkludert inspeksjoner på stedet, jf. GDPR art. 28 nr. 3 bokstav h.

10.2. Databehandler gir innsyn i nødvendig dokumentasjon. For underdatabehandlerne (Supabase, Vercel, Mailjet, Signicat) aksepteres fremleggelse av **SOC 2 Type II-rapporter, ISO 27001-sertifiseringer eller annen tilsvarende dokumentasjon** som tilstrekkelig bevis i første instans. «Tilsvarende dokumentasjon» omfatter blant annet:

- leverandørens offentlige Data Processing Agreement (DPA) med SCC;
- leverandørens Transfer Impact Assessment (TIA);
- leverandørens Trust Center / Security-portal med publiserte kontroller;
- underleverandørers compliance-sertifikater der dette danner grunnlaget for leverandørens egen infrastruktur (f.eks. AWS SOC 2 / ISO 27001 for Supabase og Vercel som begge hostes på AWS);
- leverandørens Transparency Reports om myndighetsforespørsler.

Se **Vedlegg B.3** for en dokumentert oversikt over hvilken dokumentasjon som dekker hvilken GDPR-forpliktelse, jf. GDPR art. 28 nr. 3 bokstav h.

10.3. Revisjon skal varsles **minst 30 dager i forveien** og gjennomføres med minimal forstyrrelse av ordinær drift. Behandlingsansvarliges utøvelse av revisjonsretten skal ikke medføre represalier overfor Databehandler.

10.4. Kostnader for ordinær årlig revisjon (opptil én per kalenderår) bæres av Behandlingsansvarlig. Kostnader ved revisjon utløst av sikkerhetsbrudd eller vesentlig mislighold hos Databehandler bæres av Databehandler.

§11. Mislighold og erstatning

11.1. **Hovedregel.** Erstatningsansvar mellom partene for forhold som omfattes av denne DBA-en reguleres av Hovedavtalens alminnelige ansvarsregler og norsk bakgrunnsrett, med de presiseringer som følger av §§ 11.2 og 11.3 under.

11.2. **Ansvar overfor registrerte (GDPR art. 82).** Partene er solidarisk ansvarlige overfor registrerte for skade som skyldes behandling i strid med GDPR, jf. art. 82 nr. 4. Denne bestemmelsen er preseptorisk. Den registrertes rett til å

kreve full erstatning fra enten Behandlingsansvarlig, Databehandler eller begge står uberørt.

Har én part betalt mer enn sin andel av erstatning til registrerte, har parten regress mot den andre i samsvar med partenens faktiske ansvar for bruddet, jf. GDPR art. 82 nr. 5.

11.3. **Fullt ansvar for forsett og konfidensialitetsbrudd.** Uavhengig av øvrig avtaleregulering bærer partene fullt ansvar overfor hverandre for skade som skyldes:

- (i) forsett eller grov uaktsomhet;
- (ii) brudd på konfidensialitetsplikten etter §3.2.

§12. Varighet og oppsigelse

12.1. Avtalen gjelder så lenge SaaS-hovedavtalen er i kraft.

12.2. Ved opphør av Hovedavtalen opphører automatisk også denne DBA, med unntak av sluttbestemmelser og sletteplikter i §9 samt konfidensialitetsplikten etter §3.2.

§13. Lovvalg og verneting

13.1. Avtalen er underlagt **norsk rett**.

13.2. Dersom tvist oppstår, skal partene først forsøke å løse den ved forhandling. Verneting er **[FYLL INN kommunens rettskrets, typisk tingretten der kommunen har sin administrasjon]**.

13.3. Dette påvirker ikke registrertes rett til å klage til Datatilsynet eller bringe sak inn for vernetinget etter GDPR art. 79, eller kommunens rett til å melde brudd til Datatilsynet etter GDPR art. 33.

§14. Språk og tolkning

14.1. Avtalen er inngått på **norsk (bokmål)**. Dersom det utarbeides oversettelser til andre språk, går den norske teksten foran ved tvil.

14.2. Overskrifter er veiledende og påvirker ikke tolkningen av bestemmelsene.

Vedlegg A — Behandlingens formål og art

A.1 Formål

Drift av Boly-plattformen for:

1. Formidling av utleieboliger mellom godkjente utleiere og kommunen for kommunens tildeling av boligbistand.
2. Autentisering av utleiere og kommuneansatte via BankID (Signicat) ved inngåelse av brukervilkår og leieavtaler.
3. Administrasjon av leieavtale-signering og overtakelses- / tilbakeleveringsprosesser.
4. Rapportering og revisjonsspor for kommunen.
5. Trygg kommunikasjon mellom utleier og kommunens saksbehandlere (chat, notifikasjoner).
6. Mottak av anonym overtakelsesrapport fra leietaker via engangslenke (token-basert, uten innlogging).

A.2 Kategorier av registrerte

Registrerte brukere med konto på plattformen:

- Utleiere (`homeowner`) — private eiere av utleieobjekter.
- Saksbehandlere (`kommune_ansatt`) — kommunens ansatte.
- Kommune-administratorer (`kommune_admin`).

Øvrige personer som behandles i begrenset form:

- Avsendere av anonym overtakelsesrapport (leietakere som har mottatt engangslenke fra utleier/kommune).
Ingen brukerkonto, ingen innlogging, ingen BankID.
- Publikum / gjester — kun marketing-sider, ingen personopplysninger utover alminnelige server-logger.

Leietakere er ikke registrerte brukere av Boly-plattformen. Forholdet mellom leietaker og kommune, inkludert tildeling av boligbistand, reguleres av kommunens egne systemer og vedtak — ikke av Boly.

A.3 Kategorier av personopplysninger

Utleiere (`homeowner`):

- Navn, e-post, telefon.
- Rolle og tilgangsrettigheter.
- Kommuneregion (virkeområde).
- Foretrukket språk.
- Påloggingsstatistikk og audit-logger.
- Adresse og koordinater for boligen(e) de tilbyr.
- Husregler, visuelle rapporter (overtakelses-/tilbakeleverings rapporter), bilder.
- BankID-signeringslogg ved signering av brukervilkår eller leieavtale (transient session-id + tidsstempel; ingen fødselsnummer).
- **Bankkontonummer (valgfritt, kun ved kontobetaling):** Lagres med én rad per bolig, kun når utleier aktivt velger kontobetaling i stedet for standardvalget fakturabetaling. Informasjonen beskyttes av:
 - Region-avgrenset Row-Level Security i databasen (kun utleier selv og saksbehandlere i samme kommune ser raden).
 - Kryptering i hvile (AES-256) og i transport (TLS 1.2+).
 - Automatisk sletting 24 måneder etter siste oppdatering når boligen ikke lenger er aktivt formidlet.
 - Umiddelbar sletting når selve boligannonse slettes (kaskade).
- Valgfritt org.nr. dersom utleier opererer under ENK/AS.

Saksbehandlere / kommune-admin:

- Navn, e-post, telefon.
- Rolle og tilgangsrettigheter.
- Kommuneregion.
- Foretrukket språk.
- Påloggingsstatistikk og audit-logger.
- Kommune-interne rettighetsflagg (f.eks. `kommune_can_edit`).
- BankID-signeringslogg ved pålogging / signering (transient session-id + tidsstempel; ingen fødselsnummer).

Anonyme overtakelsesrapporter fra leietaker:

- Fritekstkommentar om boligen (valgfritt).
- Opplastede bilder (valgfritt).
- IP-adresse registrert i alminnelige serverlogger hos underdata behandler, på linje med all annen nettbruk. Loggene brukes kun til drift og sikkerhet og korreleres ikke mot andre identifikatorer.
- **Ingen** navn, e-post, telefonnummer, BankID-identifikator, brukerkonto, samtykkelogg eller annen direkte personidentifikator innhentes av plattformen.

Leietakeren informeres i selve skjemaet om hva som lagres og hva som ikke lagres, slik at innsending er et informert valg.

A.4 Personopplysninger som IKKE behandles

Plattformen er designet etter *data minimization by design* (GDPR art. 25). Følgende lagres **ikke**:

- Fødselsnummer, DUF-nummer eller annen nasjonal identitets identifikator. Signicat **sub** er transient og persisteres aldri.
- Bankkort-PAN, CVV, eller andre betalingsinstrumentslegitimasjoner.
- Helseopplysninger (GDPR art. 9).
- Etnisitet, religion, politiske meninger, fagforeningsmedlemskap (GDPR art. 9).
- Biometriske data (GDPR art. 9) — BankID-biometri håndteres av Signicat, ikke Boly.
- Opplysninger om straffbare forhold (GDPR art. 10).
- Passord i klartekst (Supabase Auth med bcrypt/argon2).

⚠ Viktig begrensning for saksbehandlere. Boly-plattformen er ikke konfigurert for behandling av særlige kategorier av personopplysninger (art. 9-data: helse, rus, psykiatri, etnisitet mv.). Saksbehandlere er ansvarlige for ikke å legge inn slike opplysninger i plattformen, herunder i chat-grensesnittet. Dersom slike opplysninger likevel skal behandles, kreves ny DBA-klausul og eget rettslig grunnlag.

A.5 Behandlingens varighet

Avtalens løpetid, med retensjon som spesifisert i Vedlegg C.4.

A.6 Registrertes rettigheter i plattformen

Databehandler har implementert selvbetjent innsyn og portabilitet (GDPR art. 15 og 20) direkte i brukergrensesnittet: den registrerte kan laste ned en komplett, maskinlesbar eksport (JSON) av egne personopplysninger. Eksporten inkluderer også kontakt til Behandlingsansvarliges personvernombud, slik at formelle rettighets forespørsler kan rutes riktig.

Vedlegg B — Underdatabehandlere

B.1 Godkjente underdatabehandlere

Primære avtaleparter (Tier 1 — prosesserer kundedata):

Leverandør	Behandling	Lokasjon	Rettslig grunnlag
Supabase Inc. (US morselskap) — EU-kontraktpart: Supabase Ireland Ltd. (Dublin)	Postgres-database, Auth, Storage, Edge Functions	AWS eu-central-1 (Frankfurt, Tyskland)	SCC 2021/914 modul 2 + Supabase DPA + TIA (B.2.2)
Vercel Inc. (Delaware reg. 5857312, Pro-plan)	Hosting av frontend og serverside-funksjoner. Edge Middleware på globalt CDN, persisterer ikke	arn1 (Stockholm, Sverige) — pinnet via vercel.json . Edge Middleware: globalt CDN	SCC 2021/914 modul 1+2+3 + Vercel DPA + DPF + TIA (B.2.1)
Mailjet SAS	Utsending av transaksjonelle e-poster	EU (Paris, Frankrike)	Separat DPA, SCC ikke påkrevd (EU-leverandør)

Leverandør	Behandling	Lokasjon	Rettslig grunnlag
Signicat AS	BankID-signering og identifikasjon	Norge	Separat DPA, SCC ikke påkrevd (norsk leverandør)
Kartverket / Geonorge	Offentlig adresse-oppslag (ingen personopplysninger lagres)	Norge	Offentlig tjeneste

Underleverandører i Supabase-kjeden (Tier 2 — kan prosessere kundedata):

Leverandør	Funksjon hos Supabase	Lokasjon	DPF-sertifisert?
Supabase Pte. Ltd	Intra-konsern APAC-enhet (p.t. ingen aktiv dataflyt — Boly er pinnet til eu-central-1)	Singapore	N/A — SCC + TIA §3.5
Amazon Web Services	Fysisk hosting av Postgres, Auth, Storage	EU Frankfurt	✓ Ja
Google LLC (BigQuery)	Lagring av plattform-logger	US (EU-lokal speiling)	✓ Ja
Fly.io, Inc.	Realtime WebSocket-prosessering	Globalt (EU-ruter)	✗ Nei (SCC)
Cloudflare, Inc.	CDN/WAF foran Supabase Edge	EU/global edge	✓ Ja

Underleverandører i Vercel-kjeden (Tier 2):

Leverandør	Funksjon hos Vercel	Lokasjon	Status
Amazon Web Services	Compute for Boly-funksjoner (arn1)	EU Stockholm	✓ DPF
Microsoft Azure	Komplementerende compute (ikke aktivt for arn1)	EU	✓ DPF
Google Cloud Platform	Komplementerende compute (ikke aktivt for arn1)	EU	✓ DPF

Full, dynamisk underdatabehandler-liste hos leverandørene:

- Supabase: <https://supabase.com/docs/company/terms#subprocessors> (arkivert snapshot oppbevares av Databehandler og fremlegges ved forespørsel).
- Vercel: <https://security.vercel.com>.

Ved endringer i disse listene gjelder §5.4 (videresendelse innen 48 timer, 30-dagers intern vurderingsperiode for Behandlingsansvarlig).

B.2 Transfer Impact Assessment (TIA)

For underdatabehandlere med morselskap i tredjeland (USA, Singapore) er det utarbeidet Transfer Impact Assessment i tråd med **EDPB Recommendations 01/2020 v2.0**:

- **B.2.1 — Vercel Inc.:** TIA-Vercel — vedlegges som separat dokument.
- **B.2.2 — Supabase Inc. & Supabase Pte. Ltd:** TIA-Supabase (inkluderer sekundær Singapore-vurdering) — vedlegges som separat dokument.

Begge TIA-er gjøres tilgjengelige for Datatilsynet ved forespørsel. TIA-ene skal re-vurderes:

- **Årlig.**

- **Ad-hoc** ved: ny rettsavgjørelse som berører overføringer til USA (f.eks. Schrems III, DPF-overprøving), endringer i underdata behandlers infrastruktur, eller utvidelse av behandlingsgrunnlaget.

Ingen annen overføring til tredjeland er godkjent uten ny skriftlig instruks fra Behandlingsansvarlig.

B.3 Dokumentasjonsskjede for sikkerhetskontroller

Tabellen under dokumenterer hvilke kilder som samlet oppfyller GDPR art. 28 nr. 3 bokstav h og art. 32 for hver underdatabehandler, og understøtter §10.2 om «tilsvarende dokumentasjon». Den erstatter kravet om å innhente enkelt-rapporter som forutsetter betalt Team-/Enterprise-plan hos leverandøren.

GDPR-forpliktelse	Supabase (Ireland Ltd.)	Vercel Inc.	Signicat AS	Mailjet SAS
Art. 28(3)(a) — dokumenterte instrukser	Supabase DPA + denne DBA	Vercel DPA + denne DBA	Signicat kundeavtale + DPA	Mailjet DPA
Art. 28(3)(b) — taushetsplikt	Supabase DPA §8 + ansattavtaler	Vercel DPA §8 + ansattavtaler	Signicat sikkerhetsdokumentasjon	Mailjet ISO 27001
Art. 28(3)(c) / art. 32 — sikkerhet	AWS SOC 2 Type II + AWS ISO 27001 (underliggende infra) + Supabase Trust Center (trust.supabase.com) + Supabase TIA	Vercel SOC 2 Type 2 (årlig, under NDA via security.vercel.com) + AWS/GCP/Azure SOC 2	Signicat ISO 27001 + Finanstilsynets tilsyn (som tillitstjenestetilbyder)	Mailjet ISO 27001 + SOC 2
Art. 28(3)(d) — underdatabehandlere	Supabase subprocessors-liste + denne B.1 Tier 2	Vercel security.vercel.com subprocessors + denne B.1 Tier 2	Signicat subprocessors	Mailjet subprocessors
Art. 28(3)(e) — registrertes rettigheter	Supabase DPA §7 + Boly-egen implementasjon (selvbetjent eksport)	Vercel DPA §11 + Boly-egen implementasjon	Signicat støtter via BankID-flyt	Mailjet opt-out + abuse-funksjon
Art. 28(3)(f) — bistand ved brudd	Supabase DPA §9 + varslingsklausul 72t	Vercel DPA §8.c + Security Incident-plikt	Signicat SLA	Mailjet DPA
Art. 28(3)(g) — sletting	Supabase DPA §11 + Boly-retensjon (C.4)	Vercel DPA §12	Signicat: ingen Boly-data lagres (transient)	Mailjet DPA + Boly-retensjon (C.4)
Art. 28(3)(h) — revisjon	AWS SOC 2 Type II (publikt via AWS Artifact) + Supabase Trust Center	Vercel SOC 2 Type 2 Audit Report (NDA via security.vercel.com)	Signicat ISO 27001-rapport	Mailjet ISO 27001-rapport
Art. 44–49 — tredjelandsoverføring	SCC 2021/914 modul 2 + TIA-Supabase + DPF for AWS/Google/Cloudflare (underinfra)	SCC 2021/914 moduler 1+2+3 + TIA-Vercel + DPF for Vercel Inc.	Ikke aktuelt (norsk leverandør)	Ikke aktuelt (fransk leverandør)

Konklusjon: Dokumentasjonsskjeden over er **samlet tilstrekkelig** til å oppfylle GDPR art. 28 nr. 3 bokstav h for Boly — ingen ytterligere rapport-oppkjøp er nødvendige på nåværende risikoprofil. Tilgjengelige rapporter og offentlige

DPA-er oppbevares av Databehandler. SOC 2 Type II / ISO 27001-rapporter som krever NDA eller Team-plan-abonnement innhentes ved forespørsel fra Behandlingsansvarlig eller Datatilsynet.

Vedlegg C — Tekniske og organisatoriske tiltak (TOM)

Tiltakene under beskriver kontrollenes *funksjon og effekt*, ikke de konkrete implementasjonsartefaktene. Detaljerte implementasjons beskrivelser (migrasjoner, funksjoner, policies) fremlegges av Databehandler på forespørsel under §10, eller til Behandlingsansvarliges revisor/DPO.

C.1 Tilgangskontroll

- **Autentisering:** Alle brukerkontoer er passord- eller BankID-baserte. Passord hashes med bcrypt/argon2.
- **Autorisasjon:** Rollebasert tilgangsstyring (RBAC) håndhevet på to lag: applikasjonslaget (rutebeskyttelse og middleware) og database laget (Row-Level Security).
- **Region-scoping:** Kommuneansatte ser kun data for boliger i egen kommune, håndhevet i databasen.
- **Minste privilegium:** Produksjonstilgang for Databehandlers utviklere er rolle- og tidsbegrenset; service-nøkler roteres kvartalsvis.

C.2 Tilgjengelighet

- **Backup:** Supabase PITR (Point-in-Time Recovery) innenfor `eu-central-1` . Daglige øyeblikksbilder + WAL-replikering.
- **RTO / RPO:** RTO < 4 timer, RPO < 24 timer.
- **Gjenopprettingsprøve:** Årlig.

C.3 Integritet og konfidensialitet

- **Kryptering i transport:** TLS 1.2+ for alle klient-til-server- og server-til-server-forbindelser.
- **Kryptering i hvile:** AES-256 (Supabase + Vercel standard).
- **Særlig om finansiell PII:** Bankkontonummer lagres i krypterte tablespaces; aldri i server-logger eller klartekst-eksporter.

C.4 Sletting og retensjon

Datakategori	Slettefrist	Begrunnelse	Mekanisme
Brukerkontoer (utleiere)	12 måneder etter siste aktive kontrakt	Dataminimering, men lang nok til at utleier kan komme tilbake uten full reregistrering	Manuell + varsling
Brukerkontoer (saksbehandlere)	Senest 30 dager etter avsluttet arbeidsforhold	Formålet er bortfalt; kortest forsvarlige vindu for å avvikle tilgang og eksportere utestående oppgaver	Kommunen varsler
Chat-meldinger og vedlegg	24 måneder	Dekker reklamasjons-/klagevindu i leieforhold; kortere enn foreldelseslovens hovedregel (3 år)	Nattlig, automatisert
Notifikasjoner	12 måneder	Operativ historikk; ikke bevisverdi etter 12 mnd	Nattlig, automatisert
Audit-logger	12 måneder	Balanserer sikkerhetsovervåking (NSM-anbefaling 6–12 mnd) mot dataminimering; lengre retensjon for bevisverdi skjer i pseudonymisert form, se §9.3	Nattlig, automatisert

Datakategori	Slettefrist	Begrunnelse	Mekanisme
Bankkontonummer	24 måneder etter siste oppdatering når boligen ikke aktivt formidles	Tillater at utleier reaktiverer samme bolig uten å måtte registrere kontonummer på nytt; slettes umiddelbart når listingen er fjernet	Nattlig, automatisert + kaskadesletting
Handover-rapporter og -bilder	36 måneder etter godkjenning eller siste endring	Matcher foreldelseslovens hovedregel (3 år, foreldelsesloven § 2) for eventuelle krav om mangler/skader på bolig	Nattlig, automatisert (både database og filer)
Signerte kontrakter / vilkårsakseptanser	5 år etter avsluttet leieforhold	Bokføringsloven § 13 (3) (endret fra 10 til 5 år i 2014). Beholdes pseudonymt etter §9.3 dersom bruker slettes. Forlenges kun ved dokumentert arkiv- eller rettsbehov.	Kommunens ansvar; pseudonymisering automatisk
Pseudonymiserte tombstone-rader (§9.3)	5 år etter pseudonymisering, deretter sletting	Tilsvare bokføringsloven § 13 (3). Raden er pseudonymisert (GDPR art. 4 nr. 5), ikke anonymisert — pseudonymiseringen fjerner <code>user_id</code> -koblingen, men raden beholder kolonner som er nødvendige for legal hold. Se §9.3 tredje ledd for hva som pseudonymiseres nå (fase 1) vs. senere (fase 2–3).	Planlagt utvidelse av retensjonsjobben, jf. Vedlegg F.1

Den nattlige retensjonsjobben loggfører hver kjøring (antall slettede rader per kategori) i Databehandlers audit-spor, slik at Behandlingsansvarlig kan verifisere at sletting faktisk finner sted.

C.5 Lokasjon for behandling

Se §6.1. All primærbehandling av personopplysninger skjer på servere innenfor EU/EØS:

- Supabase: AWS `eu-central-1` (Frankfurt).
- Vercel: `arn1` (Stockholm).
- Edge Middleware (JWT-sjekk): globalt edge-CDN, persisterer ikke.

C.6 Tredjelandsvurdering

TIA-er levert. Se Vedlegg B.2.

C.7 Logging og overvåking

- Infrastrukturlogger hos Supabase innenfor `eu-central-1`.
- Applikasjonslogger som filtrerer sensitive felter (kontonummer, tokens, chat-innhold) før utskriving.
- Audit-logger i databasen for sikkerhetshendelser og automatiserte retensjonskjøringer.

C.8 Opplæring

- Alle utviklere og driftpersonell hos Gamechanging har personvern- og sikkerhetsopplæring ved onboarding og årlig oppfriskning.
- Kommunen har ansvar for opplæring av egne saksbehandlere, herunder tydelig instruks om at særlige kategorier (art. 9-data) ikke skal legges inn i plattformen, jf. Vedlegg A.4.

C.9 Eskaleringsstige ved sikkerhetshendelse

Steg	Tid	Handling
1	T+0	Hendelse oppdaget → <code>security@bolynorge.no</code> (24/7 monitorert)

Steg	Tid	Handling
2	T+2t	Intern triasje i Gamechanging-teamet
3	T+24t	Varsel til Behandlingsansvarlig (§8.2)
4	T+72t	Behandlingsansvarlig vurderer meldeplikt til Datatilsynet (art. 33) og varsling av registrerte (art. 34)
5	T+14d	Post-mortem og tiltak dokumenteres skriftlig

Operative kontakter ved hendelse:

Part	Kontakt	E-post
Behandlingsansvarlig (primær)	[FYLL INN NAVN]	[FYLL INN E-POST]
Behandlingsansvarlig (backup)	[FYLL INN NAVN]	[FYLL INN E-POST]
Databehandler (primær / 24/7)	security@bolynorge.no	security@bolynorge.no
Databehandler (personvern)	Oskar Høgmo-Utstøl	security@bolynorge.no
Databehandler (leder)	Lars Utstøl	lars@gamechanging.no

Vedlegg D — Andre bestemmelser

D.1 DPIA (Personvernkonsekvensvurdering)

DPIA for Boly foreligger som separat vedlegg til denne DBA-en. Behandlingsansvarliges personvernombud skal gjennomgå og godkjenne DPIA-en før produksjonsbruk, og DPIA-en skal inngå i kommunens behandlingsprotokoll etter GDPR art. 30.

Art. 36-vurdering: Forhåndskonsultasjon med Datatilsynet er vurdert og foreslått **ikke påkrevd**, jf. DPIA § 5, gitt at:

- Ingen særlige kategorier (art. 9) eller straffedata (art. 10) behandles.
- Ingen automatiserte beslutninger med rettsvirkning (art. 22).
- Tredjelandsoverføringer er dekket av SCC + TIA.
- Restrisiko etter tiltak er klassifisert som Lav-Moderat.

DPIA-en oppdateres årlig eller ad-hoc ved vesentlig endring.

D.2 Cookies og e-kommunikasjonsloven

Cookiebanner og cookie-policy er implementert i produksjon.

- **Brukervendt dokumentasjon:** <https://www.bolynorge.no/personvern> §4.
- **Kategorier:** Strengt nødvendige (alltid aktivt) + Statistikk (aktivt samtykke). Ingen markedsføringskapsler.
- «**Avvis alle**» er plassert like lett tilgjengelig som «**Godta alle**», i tråd med Datatilsynets veileder og ekomloven § 2-7b.

D.3 Registrertes rettigheter

Mekanismer, frister og ansvar er beskrevet i personvernerklæringen og DPIA-en som begge følger DBA-en som separate vedlegg. Selvbetjent innsyn og portabilitet tilbys direkte i plattformen (nedlastbar JSON-eksport), og formelle GDPR-forespørsler rutes automatisk til kommunens registrerte personvernombud.

D.4 Endringer av avtalen

Endringer skal avtales skriftlig. Mindre justeringer i Vedlegg B–D som følge av oppdateringer hos underdatabehandlere kan gjøres med 30 dagers forhåndsvarsel (jf. §5.2 og §5.4).

Vedlegg E — Sjekkliste før signering

Punktene under skal være fullført eller eksplisitt kvittert før avtalen tas i bruk i produksjon for den aktuelle kommunen.

#	Punkt	Ansvarlig
1	Fyll inn kommunens navn, org.nr., adresse og verneting i front-matter, §13 og kontaktavsnittet	Begge parter
2	Registrer navn, e-post og telefon for kommunens primær- og backup-kontakt (§8.2, Vedlegg C.9)	Behandlingsansvarlig
3	Registrer kommunens personvernombud (DPO) — navn og e-post — i parter-tabellen	Behandlingsansvarlig
4	Registrer kommunens dedikerte, 24/7-monitorte sikkerhetsadresse (§8.2)	Behandlingsansvarlig
5	Legg inn DPO-kontakt for kommunens region i Boly-plattformens register over kommunale personvernombud (§4.5)	Databehandler etter oppgitt informasjon
6	DPO-gjennomgang og godkjenning av DPIA (vedlagt)	Behandlingsansvarlig
7	Registrer behandlingen og DBA-en i kommunens protokoll over behandlingsaktiviteter (GDPR art. 30 nr. 1)	Behandlingsansvarlig
8	Bekreft aktuell SaaS-hovedavtale (eller tilsvarende tjenesteavtale) mellom partene	Begge parter
9	Verifiser at gjeldende TIA-er (Supabase og Vercel) og Vercel-DPA er vedlagt	Databehandler
10	Signer i to eksemplarer — ett til hver part	Begge parter

Vedlegg F — Merknader og åpne anbefalinger

Dette vedlegget dokumenterer forhold som er **vurdert og akseptert** eller **planlagt fulgt opp**, men som ikke endrer avtalens forpliktelser. Det er inkludert for full transparens overfor Behandlingsansvarlig og Datatilsynet.

F.1 Pseudonymiseringsjobb for tombstone-retensjon

§9.3 innfører pseudonymisering ved sletting av brukerkonto. Sletting av de pseudonymiserte tombstone-radene etter 5 år (jf. C.4) implementeres som en utvidelse av den eksisterende nattlige retensjonsjobben.

Status: Teknisk design klart. Planlagt implementasjon før første 5-års milepæl (ingen data har p.t. nådd denne alderen). **Ansvarlig:** Databehandler.

F.2 Art. 9-data i chat (R-05 i DPIA)

Teknisk UI-advarsel er på plass, men det finnes ingen automatisk deteksjon som blokkerer sensitive kategorier i chat. Risikoen er mitigert gjennom opplæring (§C.8) og retensjonsvindu på 24 mnd.

Anbefalt neste trinn: Vurdere valgfri heuristisk deteksjon (f.eks. mønstre for fødselsnummer eller helsetermer) som en myk varslings før sending. **Ansvarlig:** Databehandler (teknisk vurdering), Behandlingsansvarlig (organisatorisk oppfølging).

F.3 Kvalifisert elektronisk signatur og eIDAS

BankID via Signicat gir kvalifisert elektronisk signatur (QES) etter eIDAS art. 26. Behandlingsansvarlig bør verifisere at Signicats gjeldende sertifikatbevis er arkivert sammen med signerte kontrakter som del av bokføringslovens dokumentasjonskrav.

F.4 Forholdet til sosialtjenesteloven og offentlighetsloven

Plattformens primærformål (kommunal boligbistand) er en lovpålagt oppgave etter sosialtjenesteloven § 15. Kommunen vurderer selvstendig om innsynsbegjæringer etter offentleglova skal unntas etter § 13 (jf. forvaltningsloven § 13) med henvisning til taushetspliktbelagt informasjon. Databehandler bistår ved fremfinning.

F.5 Ansvarsforhold ved feil i felles RLS-lag

Både Databehandler og Behandlingsansvarliges brukere skriver data i samme database. Ved en eventuell feil i RLS som påvirker kryss-kommunal isolasjon, gjelder §11 (solidarisk ansvar overfor registrerte + regress mellom partene). Tekniske tiltak er beskrevet i C.1.

F.6 Fremtidige utvidelser som krever ny vurdering

Følgende endringer vil utløse ny DPIA-vurdering og potensielt endret DBA:

- Introduksjon av automatiserte beslutninger med rettsvirkning (art. 22).
- Behandling av særlige kategorier (art. 9) som del av ordinær datamodell.
- Overføring av persondata til land utenfor EU/EØS utover det som dekkes av gjeldende TIA-er.
- Endring av hosting-region for Supabase eller Vercel ut av EU/EØS.
- Tillegg av profilerings-SDK-er eller markedsføringssporere.

Signatur

Avtalen underskrives i to eksemplarer, ett til hver part.

For Behandlingsansvarlig	For Databehandler
[FYLL INN KOMMUNENS NAVN]	Gamechanging AS
Navn: _____	Navn: Lars Utstøl
Tittel: _____	Tittel: Styreleder
Sted / Dato: _____	Sted / Dato: _____
Signatur: _____	Signatur: _____

Kontaktpersoner

Part	Navn	Stilling	E-post / Tlf
Behandlingsansvarlig (primær)	[FYLL INN]	[FYLL INN]	[FYLL INN]

Part	Navn	Stilling	E-post / Tlf
Behandlingsansvarlig (backup)	[FYLL INN]	[FYLL INN]	[FYLL INN]
Behandlingsansvarlig (DPO)	[FYLL INN]	Personvernombud	[FYLL INN]
Databehandler	Lars Utstøl	Styreleder	lars@gamechanging.no · +47 416 13 301
Databehandler (personvern)	Oskar Høgmo-Utstøl	Personvernkontakt	security@bolynorge.no
Databehandler (sikkerhet)	—	24/7 monitort	security@bolynorge.no

Referanser

Regelverk

- **GDPR:** Forordning (EU) 2016/679, særlig art. 28, 30, 32–36, 82.
- **Personopplysningsloven** (LOV-2018-06-15-38) §§ 5, 17.
- **Ekomlova** (LOV-2003-07-04-83) § 2-7b.
- **Bokføringsloven** (LOV-2004-11-19-73) § 13.
- **Foreldelsesloven** (LOV-1979-05-18-18) § 2.
- **Sosialtjenesteloven** (LOV-2009-12-18-131) § 15.
- **Forvaltningsloven** (LOV-1967-02-10) § 13 / offentleglova (LOV-2006-05-19-16) § 13.
- **eIDAS:** Forordning (EU) 910/2014 art. 26.
- **SCC:** Kommisjonens gjennomføringsavgjørelse (EU) 2021/914.
- **EDPB Recommendations 01/2020 v2.0.**
- **Datatilsynets veileder om databehandleravtaler** (2020).
- **EU–US Data Privacy Framework Adequacy Decision**, 10. juli 2023.
- **CJEU Schrems II:** Sak C-311/18 (16. juli 2020).
- **EO 14086 (2022)** — Enhancing Safeguards for United States Signals Intelligence Activities.

Vedlagte dokumenter (separate filer)

- Personvernerklæring.
- Personvernkonsekvensvurdering (DPIA) for Boly.
- Transfer Impact Assessment — Vercel.
- Transfer Impact Assessment — Supabase.
- Leverandørens egne DPA-er og relevante underbilag oppbevares av Databehandler og fremlegges ved forespørsel.

Teknisk dokumentasjon

Konkrete implementasjonsdetaljer (databasefunksjoner, RLS-policies, retensjonsjobber og pseudonymiseringsrutiner som realiserer forpliktelsene i denne DBA-en) er versjonert i Databehandlers kildekoderepositorium og fremlegges for Behandlingsansvarliges revisor/DPO eller Datatilsynet på forespørsel, jf. §10.

Dokumentet er utarbeidet av Gamechanging AS som mal for Boly-databehandleravtale. Dokumentet er ikke juridisk rådgivning og bør gjennomgås av personvernrådgiver / advokat med GDPR-kompetanse og kommunens DPO før endelig avtaleinngåelse.